

Módulo 4: Datos Sensibles y Secretos

T10: HTTP vs HTTPS, TLS y Cifrado

Carlos Rodríguez Contreras · GitHub: [karrocon](#)

 *Por qué HTTP es texto plano y cómo TLS cifra la comunicación*

Objetivos

- Entender la diferencia entre HTTP y HTTPS a nivel de tráfico de red
- Explicar el TLS handshake y los cipher suites (qué significa AES-256-GCM-SHA384)
- Configurar HSTS para forzar HTTPS en todos los clientes
- Verificar la configuración TLS de un servidor con SSL Labs

HTTP vs HTTPS – la diferencia fundamental

HTTP (puerto 80):

- Texto plano – todo legible por cualquier nodo intermedio
- Credenciales, tokens, datos PII visibles
- Vulnerable a MITM (Man-in-the-Middle)

HTTPS (puerto 443):

- HTTP + TLS (Transport Layer Security)
- Todo el tráfico cifrado entre cliente y servidor
- Autenticación del servidor (certificado)

Con Wireshark en la misma red WiFi:

```
HTTP:  username=alice&password=password123  
HTTPS: 17 03 03 00 1a 8f 2c b1 ... (cifrado)
```

TLS Handshake (simplificado)

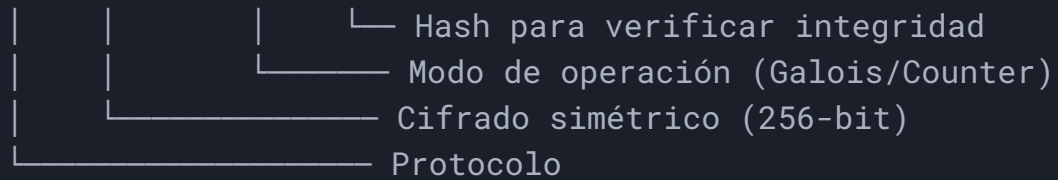
1. Cliente → ServerHello (versión TLS, cipher suites soportados)
2. Servidor → Certificate (certificado X.509 con clave pública)
3. Cliente verifica el certificado (cadena de confianza → CA)
4. Cliente → Key Exchange (genera clave simétrica, la cifra con pública del servidor)
5. Ambos → Finished (a partir de aquí, todo cifrado con AES)

Resultado: canal cifrado con:

- **Confidencialidad** — nadie puede leer el tráfico
- **Integridad** — nadie puede modificar datos en tránsito
- **Autenticación** — el servidor es quien dice ser

Cipher Suites — ¿qué significan?

TLS_AES_256_GCM_SHA384



Componente	Recomendado	Evitar
Protocolo	TLS 1.3, TLS 1.2	SSL 3, TLS 1.0/1.1
Cifrado	AES-256-GCM, ChaCha20	RC4, DES, 3DES
Key Exchange	ECDHE	RSA estático
Hash	SHA-256, SHA-384	MD5, SHA-1

HSTS — forzar HTTPS siempre

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

¿Qué hace?

1. El navegador recuerda que este dominio SOLO usa HTTPS
2. Convierte automáticamente `http://` → `https://` (sin contactar al servidor)
3. Rechaza certificados inválidos (no permite "continuar de todos modos")

⚠ Sin HSTS, la primera visita puede ser interceptada (SSL stripping). Solución: **HSTS Preload List**.

Herramientas para verificar TLS

Herramienta	URL	Para qué
SSL Labs	ssllabs.com/ssltest	Análisis completo de configuración TLS
testssl.sh	github.com/drwetter/testssl.sh	CLI para auditoría TLS
securityheaders.com	securityheaders.com	Verifica HSTS y otros headers

✓ **Objetivo:** Nota A+ en SSL Labs. En T18 configuraremos Let's Encrypt + nginx.

Errores comunes de configuración TLS

Error	Consecuencia
Certificado autofirmado	Navegador muestra advertencia, usuarios lo ignoran
TLS 1.0/1.1 habilitado	Vulnerable a POODLE, BEAST
Sin HSTS	Primera conexión puede ser HTTP (SSL stripping)
Certificado expirado	Alerta de seguridad, pérdida de confianza
Mixed content	Recursos HTTP en página HTTPS → warning
Wildcard excesivo	*.*.dominio.com → reduce aislamiento

Certificate Transparency y pinning

Certificate Transparency (CT):

- Registro público de todos los certificados emitidos
- Permite detectar certificados fraudulentos emitidos para tu dominio
- Los navegadores modernos rechazan certs sin registro CT

Certificate Pinning (HPKP – deprecated):

```
# ⚠ Ya NO se recomienda (riesgo de DoS a tu propia web)  
Public-Key-Pins: pin-sha256="..."; max-age=5184000
```

Alternativa moderna: Expect-CT + monitorización de CT logs

```
Expect-CT: max-age=86400, enforce, report-uri="https://report.example.com"
```

💡 Usa servicios como **crt.sh** para monitorizar certificados emitidos para tus dominios.

Lab T10: Wireshark – capturando tráfico HTTP

Objetivo: ver la diferencia entre tráfico HTTP plano y HTTPS cifrado

Setup: Wireshark + VulnApp en HTTP (puerto 3000) y HTTPS (puerto 3443)

1. Inicia una captura en Wireshark con filtro `tcp.port == 3000`
2. Envía credenciales de login a VulnApp por HTTP
3. Observa las credenciales en claro en el tráfico capturado
4. Repite con HTTPS (puerto 3443) y comprueba que el payload es ilegible

 **Herramienta:** [SSL Labs](#) – análisis gratuito de configuración TLS